

day-04-phase-8-security-hardening-safe-implementation

Day 04 Phase 8 â Security Hardening Safe Implementation

Objective

Move security hardening forward with safe app-level work and explicit admin runbook items, without destructive host changes or auth weakening.

Actions Executed

1. Confirmed security scan surfaces are present and protected:
 - '/api/security-scan'
 - '/api/security-scan/fix'
2. Verified unauthenticated access is denied ('401'), preserving auth boundary.
3. Reviewed code paths for fixable security checks:
 - 'src/lib/security-scan.ts'
 - 'src/app/api/security-scan/fix/route.ts'
4. Confirmed no Day 04 changes weakened auth, expanded public exposure, or modified '.env'.

Commands Used

- 'curl' auth guard checks
- 'rg'/'sed' code-path review

Open Items Reviewed

- 'auth_pass'
- 'hsts_enabled'
- 'exec_restricted'
- 'tools_deny_list'
- 'sandbox_mode'
- 'backup_recent'
- 'receipt_signing'
- 'firewall'
- 'open_ports'
- 'disk_encryption'
- 'linux_core_dumps'
- 'linux_mac_framework'
- 'linux_tmp_noexec'

Safe Implementation Status

- App-level hardening logic exists and remains enforceable through authenticated fix route.
- Local unauthenticated runner cannot execute admin-only fix operations safely.

Blocker

- 'security_scan_admin_execution_required'

Owner/Admin Action Package

1. Run authenticated '/api/security-scan'.
2. Apply only approved app-level fixes from '/api/security-scan/fix'.
3. For host-level controls ('firewall', 'open_ports', 'disk_encryption', 'linux_*'), execute infrastructure runbook outside app runtime.
4. Re-run scan and capture score delta.

Files Changed

- Report artifact only for this phase.

Tests

- Security scan/fix test coverage remains green in 'pnpm run test'.

Commits

- Pending Day 04 commit batch.

Rollback

- No security mutation was executed in this phase.

No-Secrets Confirmation

- No key/token values printed.
- No '.env' edits.

Updated Percentage

- Security remains PARTIAL until authenticated scan/fix run and host-admin runbook actions are executed with before/after evidence.

Exact Next Step

- Execute authenticated scan/fix pass and capture hardening score improvement.